

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

Contexto empresa: TechSolutions Inc.

TechSolutions Inc. es una empresa ficticia dedicada a desarrollar y vender software personalizado para pequeñas y medianas empresas (PyMEs). La empresa ofrece servicios que van desde la consultoría y análisis de requerimientos hasta el desarrollo, implementación y soporte técnico de soluciones de software.

En TechSolutions Inc., cada proceso está claramente definido y alineado con los objetivos de la empresa. Los roles están bien distribuidos, asegurando que cada persona se enfoque en tareas específicas para optimizar la eficiencia y efectividad. La implementación de diversas tecnologías permite automatizar tareas, mejorar la comunicación y facilitar la gestión de proyectos y recursos. Al integrar BPM, TechSolutions Inc. puede mejorar continuamente sus procesos, adaptándose rápidamente a cambios en el mercado y necesidades de los clientes.

Procesos Clave

1. Proceso de Ventas y Marketing
 - Generación de leads
 - Calificación de leads
 - Presentación de demos y propuestas
 - Negociación y cierre de ventas
2. Proceso de Gestión de Proyectos
 - Planificación del proyecto
 - Asignación de recursos
 - Seguimiento y control del proyecto
 - Entrega y cierre del proyecto
3. Proceso de Desarrollo de Software
 - Análisis de requerimientos
 - Diseño de software
 - Programación y pruebas
 - Implementación y despliegue
4. Proceso de Soporte Técnico
 - Recepción y categorización de tickets
 - Resolución de incidencias
 - Mantenimiento preventivo
 - Actualizaciones y mejoras

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

5. Proceso de Recursos Humanos

- Reclutamiento y selección
- Capacitación y desarrollo
- Evaluación de desempeño
- Gestión de nómina y beneficios

Personas y Roles

1. Proceso de Ventas y Marketing

- Roles:
 - Gerente de Ventas: Supervisa al equipo de ventas, establece metas y estrategias.
 - Ejecutivo de Ventas: Gestiona los leads, realiza presentaciones y cierra ventas.
 - Especialista en Marketing: Genera campañas de marketing y gestiona redes sociales.

2. Proceso de Gestión de Proyectos

- Roles:
 - Gerente de Proyectos: Planifica, coordina y supervisa los proyectos.
 - Coordinador de Proyectos: Asiste al gerente de proyectos y gestiona tareas diarias.
 - Analista de Proyectos: Realiza análisis y seguimiento de métricas del proyecto.

3. Proceso de Desarrollo de Software

- Roles:
 - Desarrollador de Software: Programa y prueba el software.
 - Arquitecto de Software: Diseña la estructura del software.
 - Tester/QA: Realiza pruebas para asegurar la calidad del software.

4. Proceso de Soporte Técnico

- Roles:
 - Gerente de Soporte Técnico: Coordina el equipo de soporte y prioriza incidentes.
 - Técnico de Soporte: Resuelve incidencias y realiza mantenimiento preventivo.
 - Especialista en Atención al Cliente: Gestiona la recepción de tickets y comunica con clientes.

5. Proceso de Recursos Humanos

- Roles:
 - Gerente de Recursos Humanos: Supervisa las actividades del departamento de RRHH.
 - Especialista en Reclutamiento: Realiza procesos de selección y contratación.
 - Coordinador de Capacitación: Gestiona programas de capacitación y desarrollo.

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

Tecnologías Implementadas

1. Proceso de Ventas y Marketing

- CRM: Salesforce para la gestión de leads y seguimiento de clientes.
- Plataformas de Marketing: HubSpot para automatización de marketing y campañas de correo electrónico.

2. Proceso de Gestión de Proyectos

- Software de Gestión de Proyectos: Asana para planificación y seguimiento de tareas.
- Herramienta de Colaboración: Slack para comunicación y colaboración del equipo.

3. Proceso de Desarrollo de Software

- IDE: Visual Studio Code para desarrollo de software.
- Control de Versiones: Git y GitHub para gestión de código fuente.
- Plataforma de Integración Continua: Jenkins para pruebas y despliegue continuo.

4. Proceso de Soporte Técnico

- Sistema de Ticketing: Zendesk para la gestión de incidencias y soporte técnico.
- Base de Conocimiento: Confluence para documentación y soluciones comunes.

5. Proceso de Recursos Humanos

- Software de Gestión de Recursos Humanos: BambooHR para gestión de nómina, beneficios y desempeño.
- Plataforma de Capacitación: LinkedIn Learning para capacitación y desarrollo de empleados.

Responder las siguientes preguntas con la finalidad de reducir los riesgos de ciberseguridad en la empresa TechSolutions Inc., para mitigar las vulnerabilidades en diversas áreas tecnológicas:

- ¿Qué medidas de autenticación y autorización están implementadas para proteger el acceso a los sistemas internos?
- ¿Se realiza regularmente la evaluación de vulnerabilidades y pruebas de penetración en todos los sistemas?
- ¿Está el sitio web protegido contra ataques comunes como XSS, CSRF y SQL Injection?

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

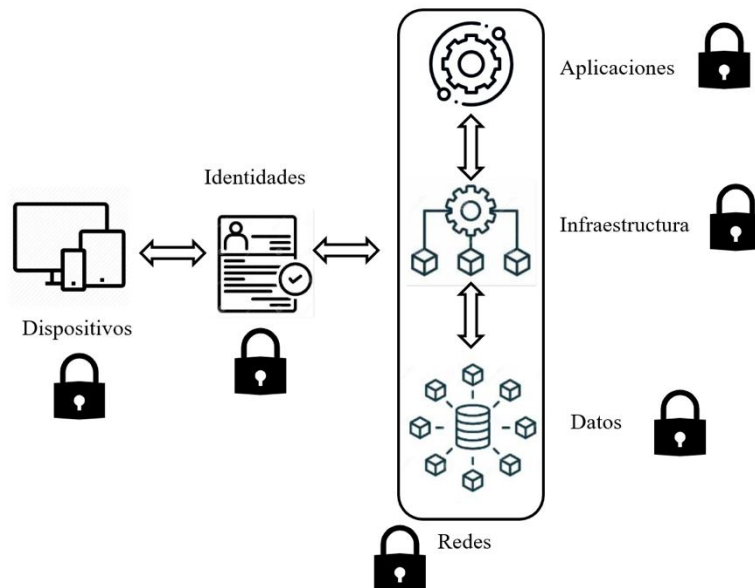
- ¿Utiliza HTTPS en todas las páginas web para asegurar la comunicación cifrada?
- ¿Existe una política de actualización y parcheo para todos los servidores y aplicaciones web?
- ¿Están las aplicaciones móviles diseñadas con medidas de seguridad para proteger los datos sensibles almacenados en el dispositivo?
- ¿Se realizan auditorías de seguridad en el código de las aplicaciones móviles antes de su despliegue?
- ¿Están las aplicaciones móviles configuradas para solicitar permisos mínimos necesarios?
- ¿Están los dispositivos IoT configurados con contraseñas fuertes y únicas?
- ¿Se aplica cifrado de datos para la comunicación entre dispositivos IoT y la red interna?
- ¿Existe una política de actualización de firmware y software para dispositivos IoT?
- ¿Cómo se gestionan las credenciales y accesos a los servicios en la nube (AWS, Azure, GCP)?
- ¿Se aplican políticas de seguridad como la segmentación de redes y el uso de roles con permisos mínimos en la nube?
- ¿Están los datos en la nube cifrados tanto en tránsito como en reposo?
- ¿Se utilizan tokens de autenticación seguros (como JWT) para el acceso a las API's?
- ¿Están las API's protegidas contra ataques de denegación de servicio (DoS) y otras amenazas comunes?
- ¿Se realiza un registro y monitoreo exhaustivo de las actividades de las API's para detectar comportamientos anómalos?
- ¿Se protegen los datos de entrenamiento y modelos de machine learning contra accesos no autorizados?

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

- ¿Existe un proceso para verificar la integridad de los datos utilizados en el entrenamiento de modelos de machine learning?
- ¿Cómo se gestionan las dependencias y bibliotecas de terceros utilizadas en los proyectos de machine learning para evitar vulnerabilidades conocidas?
- ¿Se implementan medidas para evitar el acceso no autorizado a los modelos de lenguaje grande (LLM) y sus datos?
- ¿Se realiza una evaluación de riesgos de seguridad antes de la implementación de LLMs en producción?
- ¿Se establecen controles para evitar el uso indebido de LLMs, como la generación de contenido malicioso?
- ¿Se dispone de un plan de respuesta a incidentes de ciberseguridad que incluya acciones específicas para cada área tecnológica?
- ¿Se llevan a cabo capacitaciones regulares en ciberseguridad para todo el personal de la empresa?

Considerando los puntos anteriores mencionados y realizando una reflexión de los componentes involucrados en la arquitectura Zero Trust, responder las siguientes preguntas.

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.



- ¿Qué principios fundamentales sustentan el enfoque de seguridad de Zero Trust?
- ¿Cómo se diferencia Zero Trust de los modelos de seguridad tradicionales basados en perímetros?
- ¿Qué rol juega la autenticación multifactor (MFA) en una arquitectura Zero Trust?
- ¿Qué pasos debe seguir una organización para implementar una estrategia de Zero Trust de manera efectiva?
- ¿Cómo puede la microsegmentación de red contribuir a la implementación de un modelo Zero Trust?

Riesgos en tecnología web.

- ¿Cómo se puede prevenir la inyección SQL en una aplicación web?
- ¿Cuáles son las diferencias entre un ataque XSS almacenado y un XSS reflejado, y cómo se pueden mitigar ambos?

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

- ¿Qué medidas se pueden tomar para proteger una aplicación web contra ataques CSRF?
- ¿Qué es la deserialización insegura y qué prácticas pueden ayudar a evitarla en el desarrollo de aplicaciones web?
- ¿Cómo puede una empresa asegurar que sus dependencias de software no introduzcan vulnerabilidades en su aplicación web?

Riesgos en tecnología móvil

- ¿Qué medidas de seguridad se pueden implementar para prevenir la ejecución de comandos del sistema a través de entradas no validadas en aplicaciones móviles?
- ¿Qué mejores prácticas aseguran que los datos sensibles estén cifrados en almacenamiento y transmisión en una aplicación móvil?
- ¿Cómo se puede mejorar la implementación de mecanismos de autenticación y gestión de sesiones en aplicaciones móviles para evitar vulnerabilidades comunes?
- ¿Qué pasos deben seguir los desarrolladores para asegurar que las bibliotecas y paquetes utilizados en una aplicación móvil estén actualizados y libres de vulnerabilidades conocidas?
- ¿Cuáles son los métodos más efectivos para asegurar la sanitización y validación de entradas del usuario en una aplicación móvil para prevenir ataques como XSS y CSRF?

Riesgos en tecnología para API's.

- ¿Qué métodos de autenticación se están utilizando en nuestra API para garantizar que solo los usuarios y servicios autorizados puedan acceder a ella? ¿Estamos implementando tokens de acceso o certificados para este propósito?
- ¿Cómo estamos asegurando que los usuarios y servicios solo tengan acceso a los recursos y operaciones que realmente necesitan? ¿Estamos utilizando un control de acceso basado en roles (RBAC)?

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

- ¿Qué medidas hemos implementado para proteger nuestra API contra ataques de falsificación de solicitudes entre sitios (CSRF)? ¿Estamos utilizando tokens anti-CSRF y asegurándonos de que todas las solicitudes requieran autenticación?
- ¿Qué procesos de validación y sanitización de datos hemos implementado para todas las entradas de usuario y datos recibidos a través de la API? ¿Cómo prevenimos ataques de inyección de SQL y scripting entre sitios (XSS)?
- ¿Tenemos un sistema robusto de registro y monitoreo en funcionamiento para detectar y responder rápidamente a posibles amenazas o comportamientos anómalos? ¿Cómo registramos los eventos de seguridad para permitir un análisis forense en caso de incidentes?

Riesgos en tecnología para Machine Learning (ML).

- ¿Qué métodos de autenticación se están utilizando en nuestra API para garantizar que solo los usuarios y servicios autorizados puedan acceder a ella? ¿Estamos implementando tokens de acceso o certificados para este propósito?
- ¿Cómo estamos asegurando que los usuarios y servicios solo tengan acceso a los recursos y operaciones que realmente necesitan? ¿Estamos utilizando un control de acceso basado en roles (RBAC)?
- ¿Qué medidas hemos implementado para proteger nuestra API contra ataques de falsificación de solicitudes entre sitios (CSRF)? ¿Estamos utilizando tokens anti-CSRF y asegurándonos de que todas las solicitudes requieran autenticación?
- ¿Qué procesos de validación y sanitización de datos hemos implementado para todas las entradas de usuario y datos recibidos a través de la API? ¿Cómo prevenimos ataques de inyección de SQL y scripting entre sitios (XSS)?
- ¿Tenemos un sistema robusto de registro y monitoreo en funcionamiento para detectar y responder rápidamente a posibles amenazas o comportamientos anómalos? ¿Cómo registramos los eventos de seguridad para permitir un análisis forense en caso de incidentes?

Riesgos en tecnología para Large Language Models (LLM).

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

- ¿Qué medidas de seguridad están implementadas para detectar y prevenir la manipulación de prompts que busquen acceso no autorizado, filtraciones de datos o comprometer la toma de decisiones?
- ¿Cómo se asegura que los resultados generados por el LLM sean validados correctamente para evitar vulnerabilidades de seguridad, como la ejecución de código malicioso?
- ¿Qué estrategias existen para proteger la integridad de los datos de entrenamiento y prevenir que una reducción gradual comprometa la seguridad, precisión o comportamiento ético del LLM?
- ¿Qué mecanismos de control de carga se han implementado para evitar que una sobrecarga de peticiones mediante prompts afecte los recursos computacionales y provoque interrupciones en el servicio o aumente los costos operativos?
- ¿Qué protocolos se siguen para evitar la divulgación de datos confidenciales en los resultados generados por el LLM, y cómo se manejan las consecuencias legales o la pérdida de credibilidad en caso de que ocurra una filtración?

Referencias

- Rose, S. , Borchert, O. , Mitchell, S. and Connelly, S. (2020), Zero Trust Architecture, Special Publication (NIST SP), National Institute of Standards and Technology, Gaithersburg, MD, [online], 10.6028/NIST.SP.800-207
- Cusick, James. (2018). The General Data Protection Regulation (GDPR): What Organizations Need to Know. CT Corporation Resource Center.
- Seaman, Jim. (2023). Zero Trust Security Strategies and Guideline. 10.1007/978-3-031-09691-4_9.
- Garbis, Jason & Chapman, Jerry. (2021). Zero Trust Security: An Enterprise Guide. 10.1007/978-1-4842-6702-8.
- Sarkar, Sirshak & Choudhary, Gaurav & Shandilya, Shishir K & Hussain, Azath & Kim, Hwankuk. (2022). Security of Zero Trust Networks in Cloud Computing: A Comparative Review. Sustainability. 14. 11213. 10.3390/su141811213.



Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

- Alawneh, Muntaha & Abbadi, Imad. (2023). Approaches for Zero Trust Adoption Based upon Organization Security Level. 10.1007/978-981-99-0272-9_36.
- Cheng, Ruizhi & Chen, Songqing & Han, Bo. (2023). Towards Zero-trust Security for the Metaverse.